

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

**MINISTRY OF EDUCATION AND TRAINING
FPT UNIVERSITY**

**A TWO-TIER COGNITIVE ARCHITECTURE FOR
AUTOMATED THREAT DETECTION AND RESPONSE
USING AGENTIC AI**

by

Nguyen Duc Binh

A thesis submitted in conformity with the requirements
for the degree of Master of Software Engineering

Supervisor:
Dr. Bui Van Hieu
Dr. Dang Van Hieu

Abstract

Security Operations Centres are judged on whether a genuine intrusion is caught in time, yet the volume they must inspect far exceeds what the analysts on duty can read. Existing responses each solve part of the problem: signature rules decide quickly but cannot interpret intent, correlation platforms aggregate evidence yet still hand humans more candidates than they can work through, and automated playbooks execute reliably only on scenarios someone anticipated. What is left for the analyst—assembling context around an alert and judging it—is exactly the part that does not scale. This thesis proposes SENTINEL, a cognitive two-tier security architecture operating fully air-gapped, which places cheap decisions before expensive ones so that reasoning is spent only where it is needed. Tier 1 is a wire-speed filter—deterministic rules, Welford anomaly scoring and a LightGBM gate—resolving baseline stream noise without invoking a language model. Surviving events reach Tier 2, a stateful agent running a locally hosted quantised model behind cryptographic guardrails, whose context is drawn from the raw log (request line, headers, payload, flow statistics) and compressed by log-template mining under an explicit token budget. Security knowledge is a retrieval corpus of 433 MITRE ATT&CK technique entries with the incident-handling procedures of NIST SP 800-61r2, indexed as dense vectors for semantic similarity and as a sparse BM25 index for exact identifiers, the two rankings combined by Reciprocal Rank Fusion; an output-side check withholds for an analyst any technique absent from that batch’s retrieved documents. Measured on benchmark intrusion datasets, Tier 1 and the ML Gate offload 90.6% of the stream, cutting median end-to-end latency to 0.88 ms from 17,174.7 ms under a single-tier LLM baseline. Delimited nonce encapsulation neutralises prompt injection structurally rather than by content recognition, resisting all 678 adversarial samples the static pre-filter cannot absorb, while HMAC-SHA256 chaining detects every core tampering mode, guaranteeing audit-trail integrity and tamper-evidence though not, given its symmetric key, cryptographic non-repudiation.

Acknowledgments

The completion of this Master's thesis would not have been possible without the invaluable support and guidance of numerous individuals and institutions.

First and foremost, I wish to express my deepest gratitude and profound respect to my academic supervisors, Dr. Bui Van Hieu and Dr. Dang Van Hieu. Through their scholarship, precise strategic orientation, and rigorous research ethics, they devoted their time to guiding my critical thinking, offering sharp professional critiques, and inspiring my scientific curiosity throughout this research. Their mentorship has shaped this thesis into a rigorous academic work and established a foundation for my future career in cybersecurity and artificial intelligence engineering.

I am deeply grateful to the Board of Management, the leadership of the FSB School of Business and Technology, and the faculty of FPT University, whose dedicated teaching equipped me with strong theoretical and practical knowledge within a professional research environment. I also thank the Leadership and my colleagues at Department C12, the National Data Center, whose trust, flexible accommodation of my schedule, and operational insights directly informed the design and empirical validation of the SENTINEL system.

Finally, and most cherished of all, I dedicate my deepest gratitude to my beloved family, especially my dear wife and our young child. Their silent sacrifices, patience, and constant encouragement during the countless late nights of system evaluation were my pillar of strength. While every effort has been made to conduct this research with rigor, limitations inevitably remain, and I welcome all constructive feedback from the examination committee and fellow researchers.

Contents

Abstract	i
Acknowledgments	ii
List of Figures	iv
List of Tables	v
List of Abbreviations	vi
1 Introduction	1
1.1 Background and Motivation	1
1.2 Objectives, Research Questions, Scope and Contributions	2
1.3 Structure of the Thesis	4
2 Theoretical Background and Literature Review	5
2.1 SOC Operational Realities and Cognitive Bottlenecks	5
2.2 Online Statistical Theory and Tier 1 Machine Learning	5
2.3 Local Large Language Models and Tier 2 Agentic Intelligence	6
2.4 Adversarial AI Security and Cryptographic Log Audit	7
2.5 Overview of Related Research and Research Gaps	8
3 System Design and Technical Implementation	10
3.1 Research Methodology	10
3.2 SENTINEL Architecture Overview and SOC Stack Integration	11
3.3 Tier 1: Wire-speed Filter and Machine Learning Gate	12
3.4 Tier 2: Stateful LangGraph Agent and Threat Memory	14
3.5 Dual-RAG Hybrid Knowledge Retrieval	17
3.6 Adversarial AI Security and Cryptographic Audit Sealing	18
3.7 SOC Dashboard and On-Premises Deployment Architecture	20
4 Experiments and Evaluation	21
4.1 Experimental Setup	21
4.2 RQ1 — Offloading and Filtration Economics	22
4.3 RQ2 — AI Security Guardrails and Forensic Integrity	25
4.4 RQ3 — Stateful Reasoning and Attribution	28
5 Conclusion	34
References	1

List of Figures

Figure 1.	SENTINEL at block level: two tiers separated by cost, with a single escalation path between them. (Source: Author)	11
Figure 2.	Tier 1 expanded. Only the ESCALATE branch reaches Tier 2; every other adjudication terminates here, which is what Chapter 4 counts as offload. (Source: Author)	13
Figure 3.	The Tier 2 agent state-graph, mirroring <code>src/agent/workflow.py</code> : an acyclic graph in which every path terminates in an executed action, an analyst hand-off, or an end of cycle. (Source: Author)	15
Figure 4.	Dual-RAG retrieval and the evidence-anchoring guardrail. The check sits on the output side: it constrains what the model may assert, not what the retriever may return. (Source: Author)	17
Figure 5.	Nonce encapsulation at the input boundary and HMAC chaining at the output boundary. The tail-truncation blind spot is drawn rather than omitted, because it follows from the construction. (Source: Author)	19
Figure 6.	Offload composition on the two streams; the tier carrying the load inverts with the attack base rate. Generated from <code>offload_vs_baserate_{stream,demo}.json</code> . (Source: Author)	23
Figure 7.	Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from <code>latency_benchmark.json</code> . (Source: Author)	24
Figure 8.	Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from <code>robustness_results.json</code> and <code>adversarial_negative_results.json</code> . (Source: Author) . . .	27
Figure 9.	Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)	30
Figure 10.	Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from <code>tier2_decision_results.json</code> . (Source: Author)	31
Figure 11.	Left: action accuracy by configuration with 95% confidence intervals; A and F share a denominator, B–E do not. Right: the four judge axes, with context precision the weak one. Generated from <code>ablation_action_scores.json</code> and <code>reasoning_eval_results.json</code> . (Source: Author)	33

List of Tables

Table 1.	Comparative analysis between SENTINEL and existing security defense paradigms	9
Table 2.	Experimental Configuration and Dataset Role Assignment	22
Table 3.	Per-Tier Offload Rate on Two Streams with Different Base Rates . .	22
Table 4.	Throughput of Control Configurations on an Identical 150-Event Stratified Subset	25
Table 5.	Guardrail Layers, Measurement Denominators, and Results	26
Table 6.	Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ and are not interchangeable.	29
Table 7.	Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore not directly comparable with A and F. Generated from ablation_action_scores.json.	32

List of Abbreviations

Abbreviation	Full Description
AI	Artificial Intelligence
APT	Advanced Persistent Threat
CTI	Cyber Threat Intelligence
DAPT	Dynamic Advanced Persistent Threat
FAISS	Facebook AI Similarity Search
FPR	False Positive Rate
GGUF	GPT-Generated Unified Format
HITL	Human-in-the-Loop
HMAC	Hash-based Message Authentication Code
LLM	Large Language Model
MITRE ATT&CK	MITRE Adversarial Tactics, Techniques, and Common Knowledge
NIST	National Institute of Standards and Technology
RAG	Retrieval-Augmented Generation
RRF	Reciprocal Rank Fusion
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center

Chapter 1

Introduction

This chapter states the research context and problem of SENTINEL—a cognitive two-tier architecture automating threat detection and incident response in Security Operations Centres (SOCs)—with the objectives, research questions, scope, and contributions of the thesis.

1.1 Background and Motivation

A mid-sized Security Operations Centre now ingests millions of log events every day [1], almost all recording ordinary activity. Because missing an intrusion costs far more than examining a harmless event, monitoring is deliberately tuned toward sensitivity, and practitioners consequently report that only a small fraction of what reaches them merits any action [2, 3]. Every additional sensor raises the alert count while the number of specialists able to read those alerts stays fixed, so the binding constraint of a modern SOC is not detection but the allocation of scarce human attention, which cannot be multiplied by buying more servers.

Three layers of countermeasure stand between the stream and the analyst: firewalls and intrusion detection systems matching static signatures, SIEM platforms correlating centralised telemetry with hand-written rules, and SOAR platforms executing pre-programmed playbooks [4]. Whatever they cannot settle arrives on an analyst's queue, where the work becomes manual—retrieving the raw log, reconstructing what the source address did around the flagged moment, checking the destination against the asset inventory, and identifying the technique the behaviour resembles before deciding to block, dismiss, or

escalate. Every step is reading and cross-referencing, and reading does not parallelise.

Two weaknesses follow, and they are the reasons this thesis exists. The first is time: an analyst needs minutes per alert while the stream arrives continuously, so a queue whose arrival rate exceeds its service rate is cleared by abandonment rather than completion. The second is context: the evidence deciding a case is scattered across records and buried in unstructured fields, so what is needed is not a pattern to match but a judgement to form. Static rules cannot express that, and signatures and playbooks recognise only what has already been described. Large Language Models supply the missing capability at three new costs: each act of reasoning takes seconds while data keeps arriving [5]; the reasoning layer becomes a target, since a log field can carry wording an attacker composed to steer the model [6] and any conclusion must be provably unaltered to serve as evidence; and internal logs may not leave the organisation, so the model must run on site on finite hardware [7].

The founding observation is the cost gap between the two kinds of decision: a statistical rule decides in under a millisecond, a language model in seconds. Four to five orders of magnitude make routing every event through the most expensive tier a systematic waste. The objective is therefore to design, build, and empirically evaluate SENTINEL, a two-tier architecture built on *placing cheap decisions before expensive ones*: a fast filtering tier settling most traffic outright, and a reasoning tier called upon only for what remains, behind protective guardrails and a cryptographically sealed audit trail, entirely on local infrastructure. What makes this a research problem rather than an engineering one is that each of those three costs must be *measured*, on real data, with metrics that cannot flatter themselves.

1.2 Objectives, Research Questions, Scope and Contributions

The general objective is operationalised as three research tasks, each paired one-to-one with a research question and the contribution it is intended to produce. Chapter 4 reports results under the same three headings.

The first task is filtration economics: a stateless dual-stage filtration pipeline operating at wire-speed, resolving the majority of telemetry at the cheap tier without consuming GPU resources. RQ1 asks: *How can a multi-tiered architecture be designed to autonomously offload security telemetry at wire-speed, thereby addressing the latency bottlenecks and resource consumption inherent in Large Language Models?* The intended contribution is to quantify the principle of placing cheap decisions before expensive ones, and to demonstrate by measurement that the offload rate is a function of the attack base rate of the stream rather than a constant of the system—a property not stated explicitly in the related literature.

The second task is the security of the reasoning layer: to protect the language model structurally rather than probabilistically, and to seal the forensic record so that any alteration is detectable. RQ2 asks: *What methodologies and security mechanisms can effectively withstand adversarial risks (such as log-substrate prompt injection) to protect the AI's reasoning flow, while simultaneously ensuring the integrity and tamper-evidence of forensic audit trails?* The intended contribution is a defence based on Delimited Data Encapsulation with random cryptographic nonces, whose essential property is independence from the block rate of any classifier: encapsulated content is processed as passive text regardless of what it says, unlike probabilistic semantic filters whose effectiveness degrades against novel variants [8].

The third task covers reasoning, attribution and human workload: a stateful reasoning engine that retrieves domain knowledge, cites the evidence it used, and routes to a human the cases that warrant one. RQ3 asks: *How can stateful reasoning capabilities and domain-specific knowledge retrieval be integrated into an AI Agent to automate intrusion analysis, attribute attack techniques, and generate transparent forensic reports, thereby reducing and accurately triaging the workload requiring human analysts?* The intended contribution is to replace rigid SOAR playbooks with a stateful agent over a STIX-aligned MITRE ATT&CK knowledge base, coupled with a deterministic RAG-anchoring guardrail requiring every emitted technique identifier to be present in that batch's retrieved documents—turning hallucination control from a hope placed in the model into a verifiable architectural constraint.

The scope is bounded as follows. The object of study is the SENTINEL architecture: a Tier 1 stateless filter, a Tier 1.75 semantic cache, a Tier 2 stateful agent running a locally hosted quantised model, hybrid retrieval over MITRE ATT&CK knowledge, and the cryptographic controls protecting both. Evaluation rests on two primary datasets, CSE-CIC-IDS2018 [9] for wide-area network telemetry and CSIC 2010 [10] for HTTP Layer 7 attacks; DAPT2020 [11] for multi-stage chains and a synthetic zero-day set serve as proof-of-concept evidence only and support no contribution claim. Adversarial evaluation uses 823 samples partitioned by provenance and never merged: 703 from published corpora (AdvBench [12], deepset [13], jackhhao [14]) as the headline denominator, 80 author-composed, and 40 cross-check. The system runs on a single air-gapped workstation; automated responses are restricted to blocking IP addresses, logging, or escalating to an analyst.

1.3 Structure of the Thesis

Chapter 2 systematises the theoretical foundations and surveys related work to establish the research gap. Chapter 3 states the research methodology and the technical design of SENTINEL. Chapter 4 presents the quantitative results, organised to follow the three research questions above, and Chapter 5 concludes.

Chapter 2

Theoretical Background and Literature Review

This chapter outlines the theoretical principles underlying the thesis—SOC bottlenecks, Tier 1 statistical and machine learning foundations, Tier 2 agentic and local LLM architectures, adversarial threats with cryptographic audit—and surveys existing AI Security systems to delineate the research gap SENTINEL addresses.

2.1 SOC Operational Realities and Cognitive Bottlenecks

Chapter 1 stated the operational consequence; this section states its architectural cause. Security monitoring aggregates telemetry from Next-Generation Firewalls, Intrusion Detection Systems and Endpoint Detection and Response agents into centralized SIEM platforms [1], at volumes far exceeding human analysis capacity [15]. The problem is not the aggregation but that every device feeding it decides by static signature or deterministic rule, so the only lever for reducing missed detections is a lower threshold, which produces more alerts rather than better ones [2]. SOAR automates the response above this layer, but a playbook fires only on a situation someone anticipated [4].

2.2 Online Statistical Theory and Tier 1 Machine Learning

A wire-speed tier constrains the method before it selects one: whatever establishes the traffic baseline must do so in constant time and memory, because an unbounded stream cannot be re-read and a per-key history cannot be held. That rules out two-pass formulations of the variance and admits the incremental recurrences of Welford [16], which carry the sample

mean μ_k and the running sum of squared deviations S_k forward one observation at a time:

$$\mu_k = \mu_{k-1} + \frac{x_k - \mu_{k-1}}{k}, \quad S_k = S_{k-1} + (x_k - \mu_{k-1})(x_k - \mu_k) \quad (2.1)$$

The standard deviation $\sigma_k = \sqrt{S_k/(k-1)}$ therefore remains available at every step, so a Z-score is evaluated against a baseline that is never stored—one that adapts as traffic shifts and leaves no retention window an attacker could wait out. Section 3.3 details the classification and caching stages built on it.

2.3 Local Large Language Models and Tier 2 Agentic Intelligence

Running the reasoning tier locally is what makes data sovereignty possible and what makes memory the binding constraint. Eight billion parameters at half precision occupy roughly 16 GB for the weights alone, before activations and the key-value cache, already exceeding the 16 GB card targeted here. Quantization represents each weight on a coarser integer grid, trading controlled numerical fidelity for a proportional reduction in footprint [17]: in GGUF Q4_K_M served through `llama.cpp`, Foundation-Sec-8B-Instruct [18], the instruction-tuned variant of the cybersecurity-specialised Foundation-Sec-8B base model [19], occupies 7–8 GB, leaving headroom on the same card for the context window and the retrieval index.

Tier 2 orchestrates reasoning through a LangGraph acyclic state graph [20] integrated with Threat Memory. Grounding it in retrieved evidence rather than parametric memory [21] raises a question the security domain answers differently from general question answering: the queries mix free prose with tokens that must match literally, such as technique identifiers, CVE numbers and port values. Dense vector search [22] handles the former and is unreliable on the latter, while sparse term matching [23] is the reverse; because their scores lie on incomparable scales, the two are combined on rank, which is the property Reciprocal

Rank Fusion exploits [24]:

$$RRF_Score(d) = \sum_{m \in M} \frac{1}{k + r_m(d)} \quad (2.2)$$

retrieving context directly from 433 STIX MITRE ATT&CK technique entries and NIST SP 800-61r2 guidance for forensic justification.

2.4 Adversarial AI Security and Cryptographic Log Audit

Integrating LLMs introduces log-substrate prompt injection [6], where attackers embed instructions in User-Agent headers or Syslog strings to hijack AI reasoning [8]. Because log content is authored by the attacker, any defense based on recognising malicious content is an unending race against novel phrasings. Pandey and Bhujang [25] measure this exposure against an LLM analyst assistant and find the danger is not where intuition places it: blunt instruction overrides suppress no classification alerts under any defense mode, yet the same strategy still reaches 15% injection success on summarisation once keyword sanitisation is applied. Persona hijacking suppresses 68% of malicious logs undefended and does not decline monotonically as defenses accumulate—structured prompting cuts it to 15%, constrained output lets it rebound to 33%—while context manipulation against summarisation succeeds in 96% of attempts undefended and 38% even under constrained output. A filter tuned against the obvious class therefore leaves the effective classes open, which is the empirical case for defending the vector structurally. SENTINEL accordingly applies Delimited Data Encapsulation with random nonce tags isolating raw inputs, with deterministic guardrails constraining outputs to three valid actions (BLOCK_IP, LOG, AWAIT_HITL).

Forensic records are sealed by HMAC-SHA256 signature chaining [26] under a local secret key. The scope of that guarantee must be stated precisely: because HMAC uses a shared symmetric key, the mechanism establishes integrity and tamper-evidence but not non-repudiation in the cryptographic sense, which requires asymmetric signatures—a boundary respected throughout the thesis.

2.5 Overview of Related Research and Research Gaps

Artificial intelligence research applied to Security Operations Centers has evolved across three architectural paradigms [27].

The first paradigm, traditional enterprise defense, comprises SIEM platforms such as IBM QRadar and SOAR systems such as Palo Alto Cortex XSOAR [1, 4], which correlate telemetry with static rules and execute predefined playbooks, so they fail on variants the rules do not anticipate. The cost of that rigidity falls on the analysts: interviewing SOC practitioners, AlAhmadi *et al.* [3] find alarm quality to be the dominant complaint, with participants describing the overwhelming majority of alarms as not worth acting on. The strength of this paradigm is very low latency—precisely the property SENTINEL’s Tier 1 inherits rather than discards.

The second paradigm, retrieval-augmented classification agents, is represented by Cyber-RAG [28], which orchestrates fine-tuned per-family classifiers behind an LLM agent and reports above 94% accuracy per attack class on SQL injection, XSS and SSTI benchmarks. It addresses the quality of analysis for events already selected, not the prior question of which events deserve it, so no wire-speed tier bounds the arrival rate at the reasoning stage.

The third paradigm, multi-agent and governance-aware agents, comprises AutoBnB-RAG [29], LanG [30] and Policy-Guided Threat Hunting [31], which should not be flattened into one description because they differ in exactly the dimension this thesis measures. AutoBnB-RAG evaluates retrieval-augmented multi-agent incident response inside the *Backdoors & Breaches* tabletop environment—coordination under simulated incidents rather than an event-processing pipeline. LanG is the closest prior work: likewise LangGraph-based with human-in-the-loop checkpoints, it reports ≈ 21 ms inference and a machine-side mean time to detect of 1.58 s, and—contrary to any claim that such systems are undefended—already ships a two-layer guardrail combining regular expressions with a Llama Prompt Guard 2 semantic classifier at 98.1% F1. Policy-Guided Threat Hunting likewise places non-LLM stages first, using a reconstruction autoencoder and a two-layer

deep reinforcement learning triage ahead of LLM contextual analysis.

The gap is therefore narrower, and more honest, than an absence of capability in prior work: cost tiering is met by Policy-Guided Threat Hunting, prompt-injection defense by LanG, local operation by several. What no single architecture assembles is the combination—(1) resolving the majority of telemetry at the statistical/ML tier under one millisecond, with the offload rate reported as a function of the attack base rate rather than as a constant; (2) stateful reasoning running locally on a 16 GB GPU under a retrieval-anchoring rule that withholds any technique the retrieved evidence does not support; and (3) prompt-injection defense whose guarantee is structural—derived from where attacker-authored text sits relative to the instruction boundary, and therefore independent of payload wording, unlike a probabilistic classifier however well it scores—together with HMAC-SHA256 forensic sealing. Table 1 contrasts SENTINEL against these paradigms.

Table 1. Comparative analysis between SENTINEL and existing security defense paradigms

Evaluation Metric	SIEM / SOAR (QRadar, XSOAR)	LLM agent systems (CyberRAG, LanG, Policy-Guided)	SENTINEL Architecture (Thesis)
Core Technology	Static correlation rules, rigid Python/JS playbooks	Agentic RAG, multi-agent orchestration, DRL triage	Welford $\mathcal{O}(1)$ + LightGBM T1, LangGraph Agent T2
Operational Goal	Centralized log aggregation and playbook response	Automated incident investigation via LLM reasoning	Resolve traffic at the cheap tier, reserve the expensive tier for cases needing reasoning
Cost Tiering	One cheap tier, no reasoning	Present in some (DRL pre-triage), absent in others; offload not reported against base rate	Two tiers: cheap first, expensive second; offload reported on two base rates
Data Sovereignty	Local enterprise	Local deployment reported; hardware envelope not always stated	100% air-gapped on a 16 GB GPU
Prompt Inj. Defense	Not applicable	Probabilistic classifiers (LanG: regex + Prompt Guard 2, 98.1% F1)	Structural guarantee, independent of payload wording
Forensic Audit	Standard text logs (editable post-compromise)	Audit log reported (LanG: <code>mcp_audit.db</code>); no cryptographic sealing	HMAC-SHA256 chain, tamper-evident

Chapter 3

System Design and Technical Implementation

This chapter states the research methodology, then the design and implementation of SENTINEL: the two-tier pipeline, Tier 1 filtration and Machine Learning Gate, the Tier 2 agentic engine and Threat Memory, Dual-RAG retrieval, adversarial controls with cryptographic audit sealing, and the local deployment architecture.

3.1 Research Methodology

The thesis follows Design Science Research: the contribution is an artefact, evaluated by measurement rather than by argument. Three pillars structure it. The statistical and machine learning pillar supplies wire-speed filtration through Welford $\mathcal{O}(1)$ online statistics for rolling Z-score detection, followed by LightGBM classification. The agentic logic pillar supplies contextual reasoning through a LangGraph state-graph orchestrating a locally hosted language model over hybrid FAISS/BM25/RRF retrieval. The adversarial security pillar supplies the defensive boundary. Efficacy is assessed across five dimensions—classification quality, processing performance, adversarial resistance, explanation coherence scored by an independent judge model, and audit integrity—mapping onto the three research questions of Section 1.2 and the three result sections of Chapter 4.

Three measurement principles govern every figure reported here: the denominator must match the question, metrics must be immune to base rate (MCC and Balanced Accuracy rather than Accuracy or binary $F1$), and every ratio must carry its denominator and coverage. Section 4.1 works through their consequences where they bite.

3.2 SENTINEL Architecture Overview and SOC Stack Integration

SENTINEL enforces a cognitive two-tier architecture whose core principle is strict decoupling of work by cost. Figure 1 presents it at block level: raw telemetry from perimeter sources enters a Redis Stream queue and is handed to Tier 1, a stateless statistical and machine learning stage that settles the majority of traffic at wire-speed; only events marked ESCALATE continue to Tier 2, a stateful language model agent performing deep contextual reasoning; and every adjudication from either tier is sealed into the same audit chain. Each block is expanded in the section named on it, so that the reader meets one level of abstraction at a time.

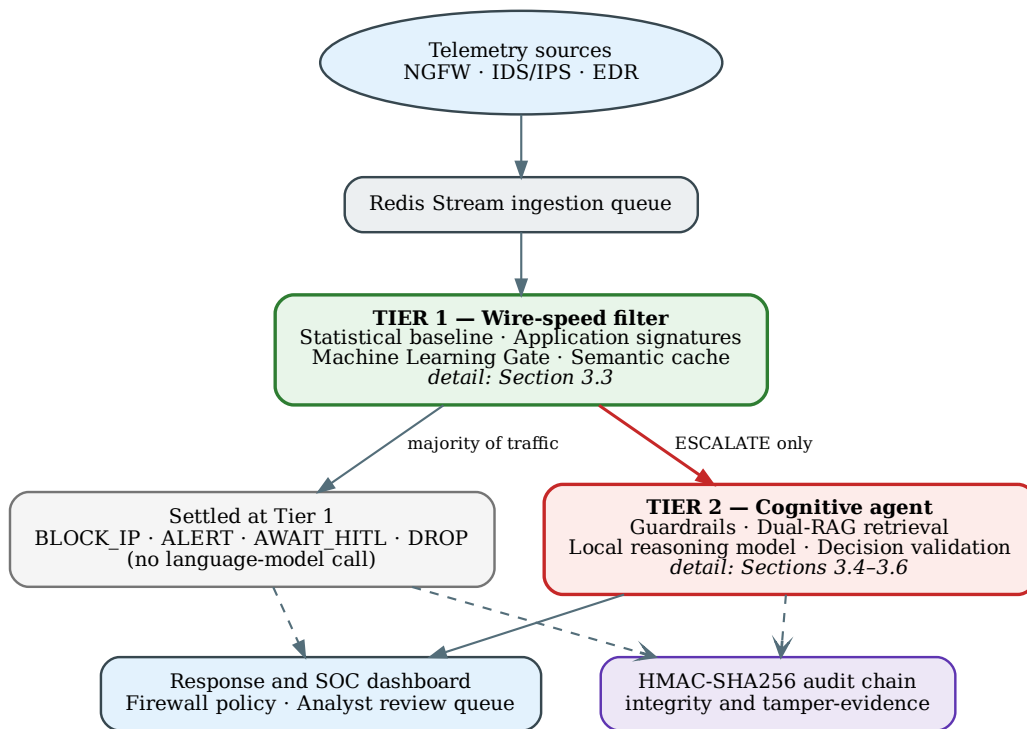


Figure 1. SENTINEL at block level: two tiers separated by cost, with a single escalation path between them. (Source: Author)

Among Tier 1's action vocabulary only ESCALATE proceeds to Tier 2, while BLOCK_IP, ALERT, AWAIT_HITL and DROP terminate at Tier 1. This grounds the offload definition used in Chapter 4: an event is offloaded when it generates no language model invocation,

whether the adjudication was to block or to pass.

At Tier 2, the LangGraph agent reasons over the locally hosted Foundation-Sec-8B-Instruct model, integrating historical state from Threat Memory and evidence from Dual-RAG, under a deterministic guardrail bounded to three states, with every record sealed by an HMAC-SHA256 chain. SENTINEL thus acts as cognitive middleware between the SIEM collector and downstream firewall or SOAR platforms, absorbing stream noise at Tier 1 and supplying cited justifications for escalated events, with data sovereignty guaranteed by air-gapped execution on a single 16 GB VRAM GPU.

3.3 Tier 1: Wire-speed Filter and Machine Learning Gate

Tier 1 is the stateless perimeter layer, combining the Welford $\mathcal{O}(1)$ baseline filter (Equation 2.1) with a LightGBM Machine Learning Gate to guarantee millisecond latency before any GPU invocation. Figure 2 expands the corresponding block.

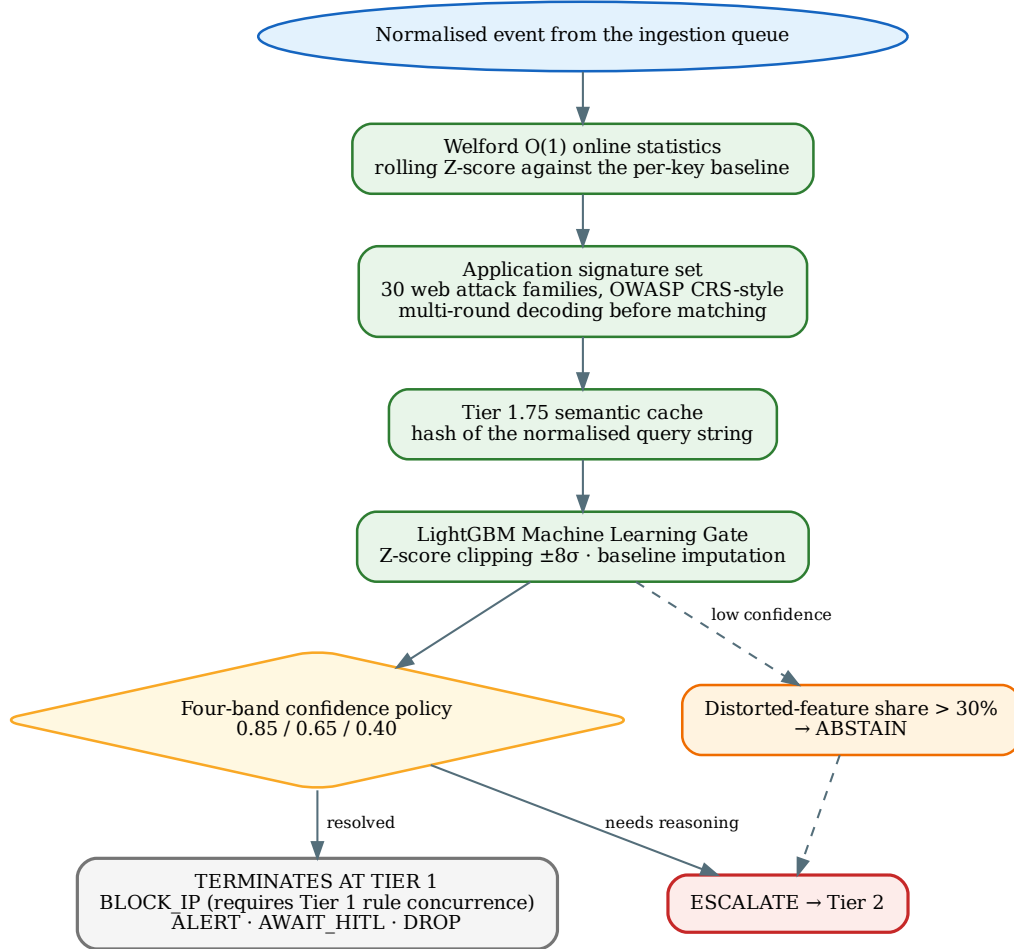


Figure 2. Tier 1 expanded. Only the ESCALATE branch reaches Tier 2; every other adjudication terminates here, which is what Chapter 4 counts as offload. (Source: Author)

The statistical filter computes $Z = (x - \mu) / \sigma$ in real time across flow attributes—packet rates, flow volumes, connection durations—with μ and σ updated by the recurrences of Section 2.2 without retaining raw series [16]; conforming traffic is shed immediately. Alongside it, Tier 1 operates an application signature set covering 30 web attack families, normalised in the OWASP CRS style so that payloads disguised by encoding are still matched. So that this set is not merely self-declared, 23 of the 30 families map onto OWASP CRS 3.3 rule files (11 distinct files) and the set spans all 10 OWASP Top 10:2021 categories; the remaining 7 are endpoint and network behaviours such as ransomware, cryptomining and credential theft, outside the scope of a rule set written for HTTP transactions. For repetitive volumetric behaviour, the Tier 1.75 Semantic Cache hashes normalised

query strings in RAM and reuses existing adjudications.

A LightGBM Gradient Boosted Decision Tree model follows, evaluating non-linear feature interactions with leaf-wise growth, trained on 949,535 NetFlow samples (664,674 training, 189,907 hold-out). To neutralise evasion the Gate clips feature Z-scores within $\pm 8\sigma$ and imputes missing values with baseline means; if distorted feature proportions exceed 30% it abstains and escalates rather than answer confidently and wrongly, since a confident error causes the system to act with no one reviewing. Adjudications map to actions through a unified four-band confidence policy (0.85 / 0.65 / 0.40 for BLOCK_IP / ESCALATE / ALERT / LOG), so that confidence *drives* the action rather than merely accompanying it; autonomous blocking is isolated to the top band and additionally requires Tier 1 rule concurrence.

3.4 Tier 2: Stateful LangGraph Agent and Threat Memory

Tier 2 executes the Foundation-Sec-8B-Instruct model [18] quantised as described in Section 2.3, served by CUDA-compiled llama.cpp on a single 16 GB VRAM GPU. Figure 3 expands the Tier 2 block.

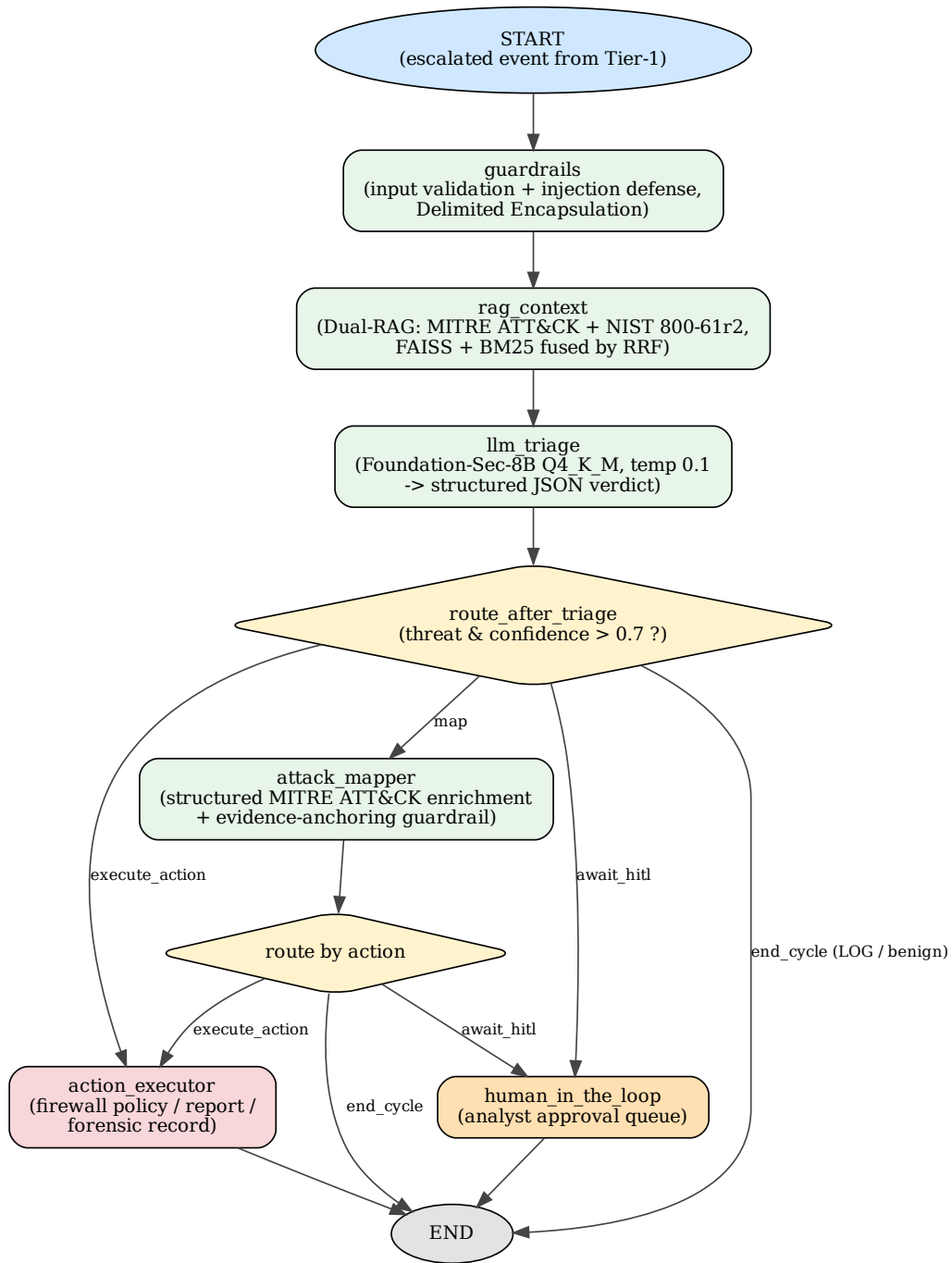


Figure 3. The Tier 2 agent state-graph, mirroring `src/agent/workflow.py`: an acyclic graph in which every path terminates in an executed action, an analyst hand-off, or an end of cycle. (Source: Author)

A LangGraph state-graph [20] orchestrates five nodes: guardrail inspection, context enrichment (`rag_context`), triage (`llm_triage`), technique mapping (`attack_mapper`),

and action execution or hand-off to `human_in_loop`. Technique mapping requires explicit verification from domain knowledge; absent an unambiguous match, the graph routes to analyst review (`AWAIT_HITL`) rather than emitting a speculative action. That path is a designed output, not a failure: the system triages the work requiring a human rather than eliminating the human. At `llm_triage` the system strips every internal classification field from the prompt—a precondition for the validity of every measurement in Chapter 4, since a ground-truth label reaching the context would let the model copy the answer rather than reason to it.

Two controls bound what may enter that cycle. Repetitive events are collapsed by Drain online log-template mining [32], so that a burst of a thousand near-identical lines costs the context window roughly what one line costs. A token budget monitor then estimates input size before each invocation and records actual usage after it, making proximity to the context ceiling an observed condition rather than a silent truncation; Section 4.3 reports what the pair achieves against a deliberately oversized input.

To correlate traces over time, Tier 2 maintains Threat Memory on an index-optimised SQLite database using rollback-journal rather than WAL, which prevents cross-UID file lock crashes under Docker, tracking IP reputation, internal entities, risk indicators and threat events. Reputation score S decays over silent period t :

$$S_{\text{new}} = S_{\text{old}} \times (1 - \lambda)^t \quad (3.1)$$

where λ is the decay rate. On reaching the maximum ($S = 100$), Tier 1 enforces block-on-sight without re-triggering Tier 2, closing a feedback loop that converts a one-time reasoning cost into a reusable adjudication. Internal infrastructure addresses are whitelisted, preventing self-inflicted denial of service.

3.5 Dual-RAG Hybrid Knowledge Retrieval

To limit hallucination and ground security decisions, Tier 2 retrieves over 433 STIX 2.1-structured MITRE ATT&CK entries [33] and NIST SP 800-61r2 guidance [34]. Two mechanisms run in parallel: dense semantic search via FAISS [22] with a Sentence-BERT embedding model [35], which finds techniques sharing intent despite keyphrase variation, and sparse keyword matching via BM25 [23], which secures exact retrieval of identifiers such as CVE codes, registry keys or service ports. Candidates are consolidated using RRF (Equation 2.2) with $k = 60$ and injected at `rag_context`. Figure 4 shows the path together with the anchoring check on the model's output.

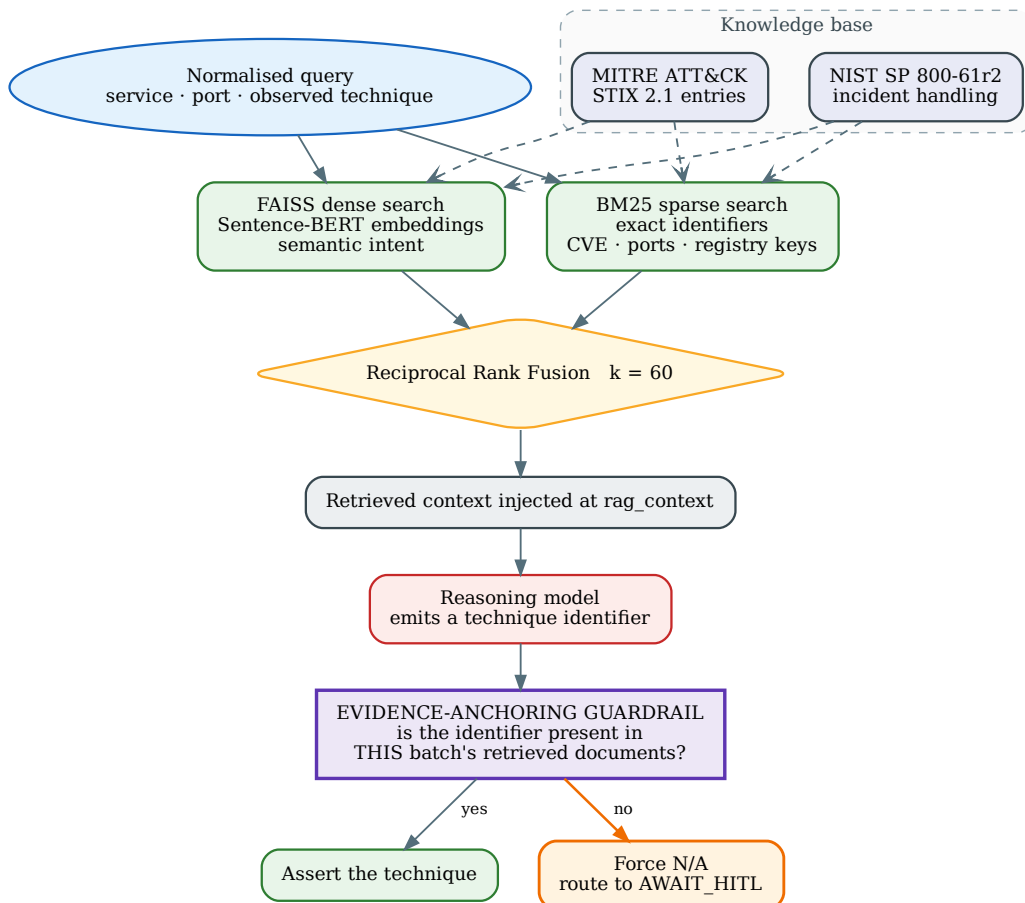


Figure 4. Dual-RAG retrieval and the evidence-anchoring guardrail. The check sits on the output side: it constrains what the model may assert, not what the retriever may return. (Source: Author)

Retrieval is itself a trust boundary, since a poisoned entry would be read as authoritative. A RAG sanitizer therefore normalises Unicode, strips markup and neutralises imperative constructions in every retrieved passage. The difficulty is that legitimate security prose is imperative—advisories instruct the reader to block, disable or isolate—so an over-eager filter silently degrades the knowledge base it protects; Section 4.3 reports the false-neutralisation rate over the entire corpus. The system then applies an evidence-anchoring guardrail: every technique identifier the model emits is checked against that batch’s retrieved documents, and identifiers absent from them are forced to N/A and routed to `AWAIT_HITL`. This is a verifiable architectural constraint rather than a dependency on how prone a given model is to hallucinate.

3.6 Adversarial AI Security and Cryptographic Audit Sealing

Log-substrate prompt injection [6] embeds control instructions inside raw telemetry fields—User-Agent headers, URI parameters, Syslog text—to hijack model behaviour. SENTINEL implements Delimited Data Encapsulation with a cryptographic nonce regenerated per batch [8], enclosing raw telemetry within nonce-bearing delimiters so the model treats the content as passive data. Per-batch generation is essential: an invariant delimiter can be inferred from source code or repeated observation, after which an attacker can close the encapsulation and escape it. Three deterministic validators guard the boundaries the model can reach. The data validator rejects malformed telemetry before it is framed as a prompt. The decision validator enforces Pydantic schema validation (`LLMDecision`), constrains the action to the permitted enumeration, and refuses block orders aimed at internal or reserved address ranges, falling back to `AWAIT_HITL` on unrecoverable formatting errors. The feedback validator applies the same zero-trust posture to rules the system proposes for itself, so that a manipulated adjudication cannot install a permanent Tier 1 rule.

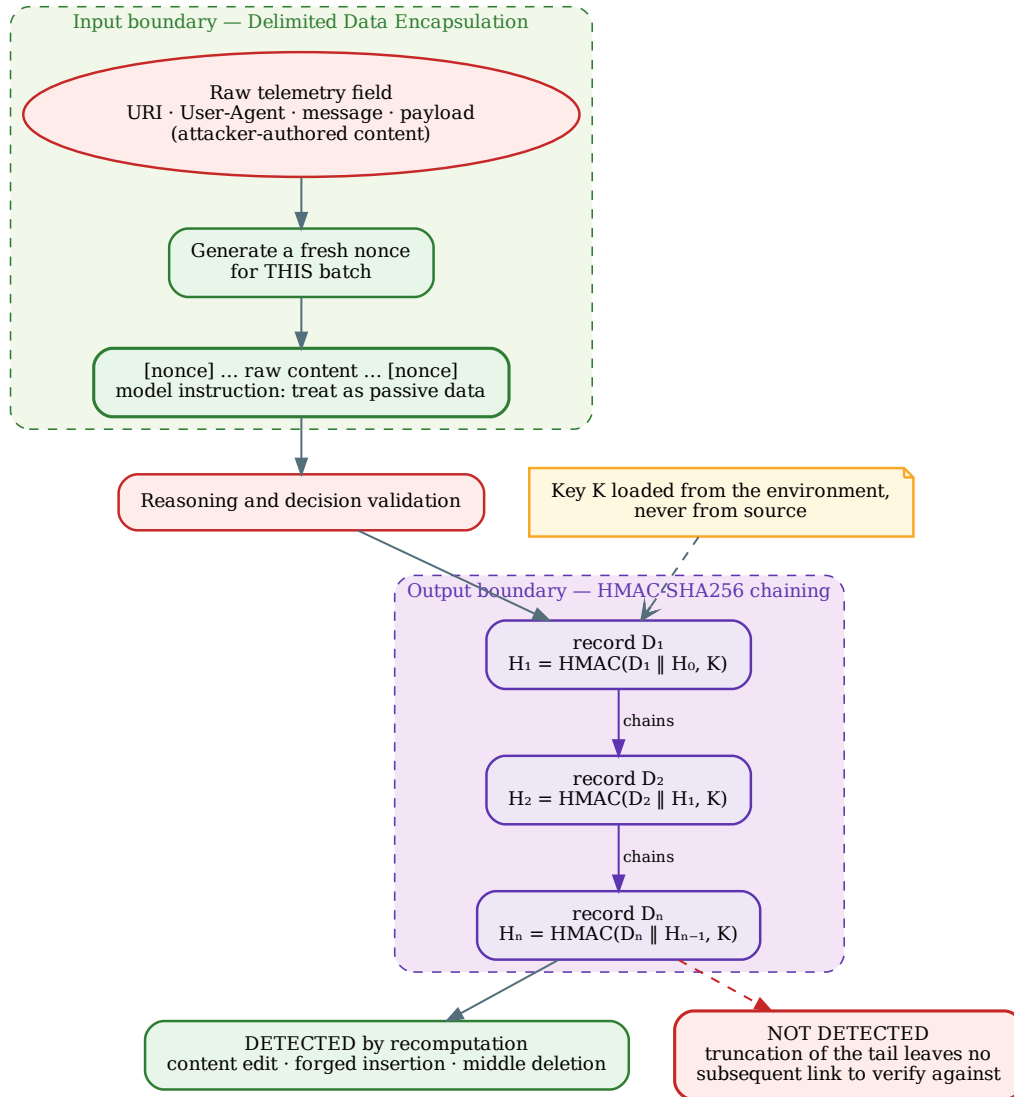


Figure 5. Nonce encapsulation at the input boundary and HMAC chaining at the output boundary. The tail-truncation blind spot is drawn rather than omitted, because it follows from the construction. (Source: Author)

For auditing, each adjudication record i is chained using HMAC-SHA256 [26]:

$$H_i = \text{HMAC-SHA256}(D_i \parallel H_{i-1}, K) \quad (3.2)$$

where D_i is the current record, H_{i-1} the preceding hash, and K a local secret key loaded from the environment rather than hardcoded, since a key exposed in source allows the entire chain to be forged. Any alteration or deletion breaks continuity and is flagged immediately,

guaranteeing integrity and tamper-evidence though not, for the symmetric-key reason given in Section 2.4, non-repudiation.

3.7 SOC Dashboard and On-Premises Deployment Architecture

The SOC Analyst Dashboard is built with Streamlit, connecting to Redis Stream and Threat Memory for real-time visibility: the per-tier offload funnel, multi-stage intrusion timelines, HMAC chain integrity, and the Human-in-the-Loop review panel. Ingestion is rate-limited by backpressure measured as consumer-group lag rather than stream length; because subscribers consume with `XREADGROUP` and `XACK`, neither of which removes entries, stream length stays pinned near its cap however promptly consumers work, so throttling on it would stall the producer against a queue that is in fact empty.

All services are containerised with Docker Compose, `llama.cpp` is compiled with CUDA for the RTX 4060 Ti, and `threat_memory.db` with the FAISS index are mounted on persistent volumes so reputation scores and audit records survive restarts. Deployment adheres to Zero Trust mandates [7]: password strings in `REDIS_URL` are redacted before logging.

Chapter 4

Experiments and Evaluation

This chapter reports the quantitative results, organised to follow the three research questions of Chapter 1. Every ratio is stated with the denominator it was measured on.

4.1 Experimental Setup

The system runs on a single air-gapped server, all microservices containerised via Docker Compose. Following Section 3.1, distribution-dependent metrics (offload rate) are measured on the live stream and classification quality on a class-balanced set; measuring offload on a forced 50/50 set would return an artificially low figure, because that set is not the distribution the system meets. Table 2 assigns each dataset its role. Two conventions hold throughout: dynamic rules are frozen during measurement, and the 50 author-composed samples inside `ground_truth.json` are excluded from every ratio, since they are 16.7% of the attribution set and all carry one answer.

Table 2. Experimental Configuration and Dataset Role Assignment

Component	Specification	Role in the Measurement
Processor (CPU)	Intel Core i7	Welford filtering and Redis streams
System RAM	32 GB DDR5	Semantic Cache and FAISS indices
Graphics Card (GPU)	RTX 4060 Ti 16 GB	11ama.cpp CUDA, Foundation-Sec-8B-Instruct [18]
Virtualization	Docker Compose	Air-gapped, reproducible environment
<code>datatest.json</code>	4,240 $\rightarrow$ 4,236 when scored, 51.8% attack	ML Gate classification quality. Drawn from CSE-CIC-IDS2018 [9], CSIC 2010 [10] and DAPT 2020 [11]. Not used for offload rate
<code>ground_truth.json</code>	1,750 samples $\rightarrow$ 1,700 when scored	Ablation, reasoning quality. 50 author-composed samples excluded from all ratios
<code>build_stream()</code>	25,799 (150 warm-up + 25,649 scored), 31.6% attack	Offload rate, end-to-end
SOC-like stream	99,717 events, 9.8% attack	Offload rate at a near-realistic base rate
Adversarial set	823 = 703 published + 80 author-composed + 40 cross-check	AdvBench [12], deepset [13], and a jailbreak collection [14] whose prompts originate in the in-the-wild study of Shen <i>et al.</i> [36]. The three provenances are scored separately and never merged

4.2 RQ1 — Offloading and Filtration Economics

An event counts as offloaded when it generates no language model invocation (Section 3.2); counting only DROP would omit BLOCK_IP, ALERT and AWAIT_HITL, none of which spend a token.

Table 3. Per-Tier Offload Rate on Two Streams with Different Base Rates

Resolving Tier	Benchmark stream, 25,649 ev		SOC-like stream, 99,717 ev	
	Events	Share	Events	Share
Tier 1 (rules + Welford + signatures)	20,663	80.6%	38,207	38.3%
Machine Learning Gate (4-band)	2,568	10.0%	58,992	59.2%
Cumulative — never reaches LLM	23,231	90.6%	97,199	97.5%
Remainder $\rightarrow$ Tier 2 (LLM)	2,418	9.4%	2,518	2.5%
<i>Attack base rate of the stream</i>	<i>31.6%</i>		<i>9.8%</i>	

Table 3 carries the contribution: the offload rate is a function of the stream’s attack base rate, not a constant of the system. Within a stream it decomposes linearly as $\text{offload}(p) =$

$(1 - p) \cdot \text{offload}_{\text{benign}} + p \cdot \text{offload}_{\text{attack}}$. The benchmark per-label rates, 92.35% benign and 86.72% attack, reproduce the measured 90.6% exactly; on the SOC-like stream, 97.88% and 93.77% reproduce 97.5%. Because the coefficients differ between streams, the relation licenses projection to another base rate within a stream, not transfer between streams—and the 90.6% is therefore not a ceiling but the consequence of a test stream loaded with more than three times the realistic attack proportion. The tier carrying the load also inverts: Tier 1 resolves 80.6% on the benchmark stream, while the ML Gate becomes the primary carrier at 59.2% on the benign-dominated one, so the two tiers compensate rather than overlap.

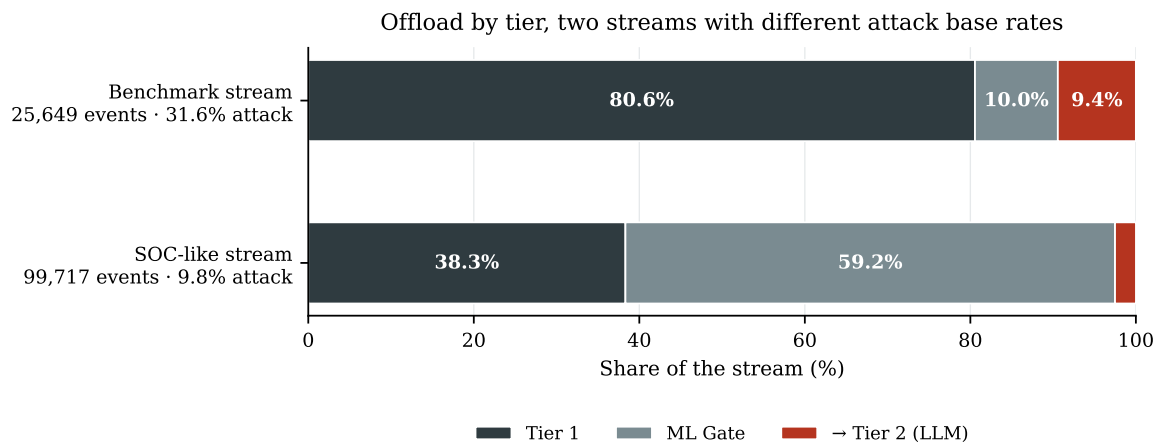


Figure 6. Offload composition on the two streams; the tier carrying the load inverts with the attack base rate. Generated from `offload_vs_baserate_{stream,demo}.json`. (Source: Author)

The ML Gate processes a feature vector in 0.287 ms (3,452 events/second) and the Tier 1.75 cache hits 81.3% of 1,500 queries at an $8.9\times$ speed-up. One quality figure belongs beside these, because a 90.6% offload rate would read the same as passing almost everything if the offloaded portion were adjudicated wrongly: on `datatest.json` the Gate reaches MCC 0.667 and Balanced Accuracy 0.833—MCC rather than Accuracy, since answering benign everywhere already scores 90.2% Accuracy on the SOC-like stream. The denominator travels with it: of 4,236 events, the Gate adjudicates 2,534, because 1,586 lack payload features and 116 abstain. Its 962 autonomous blocks achieve 100% Precision with zero false positives, which is mandatory rather than impressive: offload that blocks genuine customers is loss, not efficiency.

Harvesting 598 rules from the Gate’s blocking adjudications lowers the escalation rate from

20.28% to 17.98%, a relative reduction of 11.35%, while detection quality rises rather than falls. Two limits keep this proportionate: absolute MCC stays low ($0.071 \rightarrow 0.109$), so the mechanism is shown to operate rather than to make Tier 1 strong; and the simulation is optimistic, since the attacker never rotates source addresses and every proposed rule is approved.

On 500 events sampled strided from `build_stream()`, mean latency falls from 17,187.9 ms to 5,286.7 ms (-69.2% , Mann-Whitney U $p \approx 9 \times 10^{-57}$), and the median from 17,174.7 ms to 0.88 ms—a factor of roughly 19,500, because the typical event never reaches the model. Two results run against the system. The 95th percentile is worse, 25,829 ms against 21,434 ms, structurally so: an escalating event pays the Tier 1 and Gate cost before the model cost, so the gain sits in the median and not in the tail. And this run’s own offload rate was only 76.8%, not the 90.6% of Table 3, because 500 strided samples never accumulate enough per-address history for the blocklist to engage. Resource saving is reported as invocations avoided (97,199 of 99,717 events) rather than as a VRAM percentage, because no VRAM measurement was made.

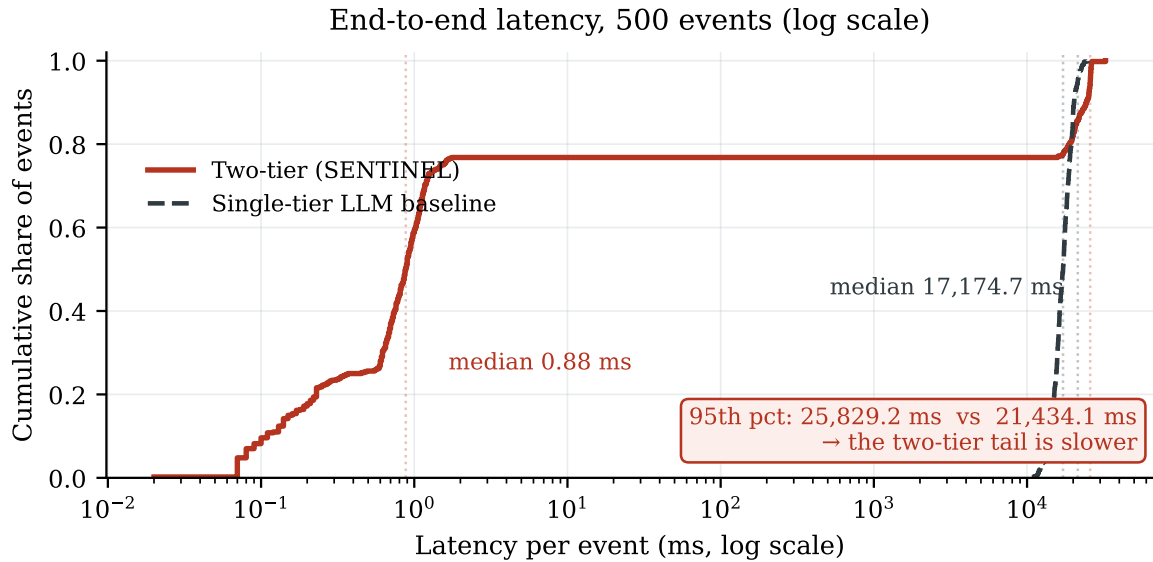


Figure 7. Cumulative latency distribution over the same 500 events. The advantage is concentrated in the body of the distribution; in the tail the two-tier system is slower. Generated from `latency_benchmark.json`. (Source: Author)

Four controls were measured on one identical 150-event stratified subset rather than by importing headline figures from other publications, which would compare across different

datasets and metric definitions.

Table 4. Throughput of Control Configurations on an Identical 150-Event Stratified Subset

Control Configuration	Throughput
H1 — Static signatures, 30 WAF families	11,129 ev/s
SENTINEL — Tier 1 + ML Gate	3,860 ev/s
H2 — Single-tier LightGBM, flat threshold	2,162 ev/s
H3 — Single-tier LLM (identical data, model, and prompt)	0.19 ev/s

The deterministic path runs $20,531\times$ faster than routing every event to the model. Static signatures are faster still, about three times SENTINEL, as expected since they perform no inference. The ordering is the architectural argument in one line: each tier costs what it costs, and the design question is how much traffic is settled before the expensive one. Two of these figures must not be combined, since the 0.19 ev/s puts each event through the full Tier 2 agent while the 17,187.9 ms baseline is a bare model call with no token ceiling. Under surge load on the 99,717-event stream, consumer-group lag backpressure keeps RAM and VRAM stable.

The block threshold sits on a flat region—0.70 through 0.85 give identical aggregate quality and only above 0.90 does recall fall—so 0.85 buys the widest margin for autonomous blocking at no measured cost, and autonomous-block precision stays 1.00 across every configuration swept. Against synthetic anomalies injected from 2σ to 100σ over seven flow features, every probe at every magnitude was escalated, so nothing passed silently; but statistical *notice* plateaus, rising from 19.52% at 2σ to 42.86% at 4σ and reaching only 54.29% at 100σ . Beyond about four standard deviations the limit is the feature set, not the threshold, so novel behaviour reaches Tier 2 by escalation rather than by recognition—the correct failure mode, but not a detection claim.

4.3 RQ2 — AI Security Guardrails and Forensic Integrity

RQ2 names log-substrate injection as a *typical* risk rather than the scope, so two structurally different surfaces are evaluated: attack through language, where resistance means an

embedded instruction fails to change the agent’s action, and attack through feature space, where resistance means a distorted sample is not flipped to benign. Three conventions make the ratios readable. The static verdict is the logical OR of three detectors recorded individually, so a failure can be located. A negative control over 230 benign logs is mandatory, because a layer that flags everything also achieves 100% blocking. And published-corpus and author-composed samples are never merged.

Table 5. Guardrail Layers, Measurement Denominators, and Results

Guardrail layer	Denominator	Result
<i>Tier 1 — attack through language</i>		
Static pre-filter, published corpora	703 samples	132 → 18.8%
by detector: pattern / encoding / delimiter	703	114 / 29 / 0
Static pre-filter, author-composed	80 samples	58 → 72.5%
Static pre-filter, cross-check set	40 samples	2 → 5.0%
Static pre-filter — false flags on benign logs	230 benign logs	46 → 20.0%
of which: encoding-detection layer	46/46	all of them
<i>Tier 1 — attack through feature space</i>		
ML Gate — evasion, hard mode (all features distorted; 13 flipped, 95% CI 97.86–99.27)	1,036 detected attacks	1,023 → 98.75%
ML Gate — single-feature modes (∞ / extreme)	$1,036 \times 2$	100% both
ML Gate — abstention on distorted input	4,236 events	116 → escalate
<i>Tier 2 — structural guarantee</i>		
Delimited nonce encapsulation	678 hard samples, coverage 100%	678 → 100%
Field-position set, by position	100 published samples	24/24, 23/23, 30/30, 23/23
Schema validation under forced backend failure	1 induced failure	AWAIT_HITL, no crash
Determinism (same seed, 5 runs) / seed-only variation	5 runs / 10 samples	identical / 0 flipped
Context-overflow guard	16,384-token window, 4,000-token budget	worst case 1,655
<i>Forensic integrity</i>		
HMAC — three core tampering modes	30 trials each	100%
HMAC — negative control (intact chain)	450 records	no false alarm
HMAC — tail truncation	—	0% — undetectable

The static pre-filter blocks 18.8% of published corpora, and that must be read with the 20.0% false-flag rate on benign logs. All 46 false flags come from the encoding-detection layer, and their cost is bounded: a static flag raises the isolation level and annotates the record but does not drop the event or block the source, so it is a rate of unnecessary annotation, not of benign traffic denied service. The author-composed subset blocks at 72.5% because 45 of those 80 samples are encoding-bypass cases the neutraliser was built for;

reporting the merged 23.3% would flatter the system by counting samples written with knowledge of the defence, so 18.8% is the figure the thesis stands behind.

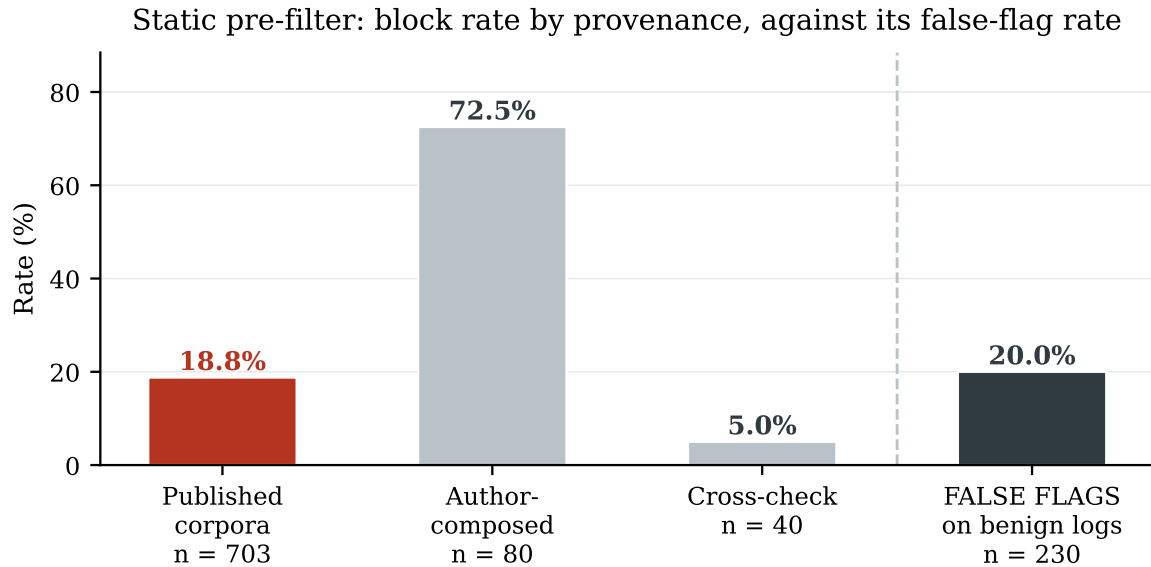


Figure 8. Static pre-filter, block rate by provenance beside the false-flag rate on benign logs. Generated from `robustness_results.json` and `adversarial_negative_results.json`. (Source: Author)

Under the hard mode, in which *every* feature of a detected attack is driven to an extreme, 98.75% of samples resist. The two single-feature modes reach 100%, and the thesis cites the hard mode rather than an average, because averaging in two trivially saturated modes would inflate the figure past what the defence demonstrated. Abstention counts as a guardrail outcome: 116 events were escalated instead of guessed.

The security guarantee comes from Delimited Data Encapsulation, evaluated at 100% coverage on all 678 samples of the seven categories the static layer does not absorb—a superset of the 543 that genuinely bypassed it, so the test is stricter than required rather than favourably sampled. Tier 2 resisted 678 of 678. That is the categorical difference: a classifier blocking $x\%$ always leaks the rest and degrades against novel variants, whereas a structural guarantee does not depend on recognising malicious content at all, so the 18.8% does not contradict the thesis but quantifies the work the structural layer absorbs. Field position is tested separately, because encapsulation wraps per field and no aggregate can probe it: across 100 samples spread over URI, User-Agent, message and payload, the static layer blocked 12 while Tier 2 resisted all 100, uniformly across the four positions. Two

robustness controls bound the LLM-dependent measurements, each with its limit: a fixed seed gave identical actions across five runs but on one sample, and varying only the seed over ten samples flipped nothing, which at $n = 10$ bounds the flip rate at just 0.2775 and saturates on a single action.

Verification recomputes the chain from the genesis record; because each link consumes its predecessor’s hash, one altered byte in D_j invalidates every link from j onward, making detection positional rather than a bare report that something changed. The three core modes—content edit, forged insertion, deleted middle record—are each detected in 30 of 30 trials, with no false alarm over 450 intact records. The measurement used a key from the environment, not the in-source default, since a key visible in source would let the chain be forged and void every rate above. Tail truncation is undetectable, an inherent property of log-chaining; the remedy is periodic anchoring of hash values outside the system.

The per-position result initially rested on 79 independent adjudications rather than 100, because the second-layer cache key omitted `user_agent` and collapsed the 23 User-Agent samples onto two fingerprints—two verdicts replayed twenty-one times, in exactly the column the experiment existed to test. A defect in the measurement apparatus and a live cache-poisoning surface were the same defect, since an attacker could equally steer a field absent from the key and be served a stored verdict. Widening the key restored 100 distinct fingerprints; the corrected result is identical to the uncorrected one, which is precisely why a denominator must be verified rather than assumed.

4.4 RQ3 — Stateful Reasoning and Attribution

RQ3’s four components—attribution, retrieval, transparent reporting and analyst workload—are measured separately, because they fail for different reasons.

Adding the reasoning tier makes attribution worse. On an identical population of 500 payload-layer samples (250 labelled, 250 benign, from CSIC 2010), retrieval alone attributes 80.0% exactly, while the full agent falls to 68.0%, and tactic-level from 80.0% to

70.4%, with median latency rising from 0.54 ms to 13,293 ms. The reasoning tier costs four orders of magnitude in time and returns twelve points less accuracy than the layer it was added to improve. Of the 30 samples lost, up to 22 are cases where the anchoring guardrail forced N/A because the proposed technique was absent from that batch’s retrieved documents—a deliberate trade of accuracy for the guarantee that the system never acts on an unsupported identifier. Any figure here reads against a floor, not zero: T1595.003 is 130 of the 250 labelled samples, so always answering it already scores 52%.

Table 6. Attribution by technique on the 500-sample payload slice, with the retrieval ceiling for the same queries. Attribution is scored on all 250 labelled samples; retrieval on the 243 of them that Tier 1 escalated, and at parent-technique granularity, so the two denominators differ and are not interchangeable.

ATT&CK technique	<i>n</i>	Retrieval hit@3	Retrieval only	Full agent
T1190 — Exploit public-facing application	52	1.00	100.0%	63.5%
T1059.007 — JavaScript execution	30	1.00	100.0%	73.3%
T1595.003 — Wordlist scanning	130	0.96	90.8%	86.9%
T1083 — File and directory discovery	12	0.00	0.0%	16.7%
T1071.001 — Web protocols	26	1.00	0.0%	0.0%
All techniques	250	0.93	80.0%	68.0%

Table 6 does what an aggregate cannot: it locates the failing tier. For T1083 the retriever never returns the correct document, so the fault is in the knowledge base and nothing downstream can recover it; for T1071.001 the retriever returns it every time and attribution is still zero, so the fault is in the mapper. The two need different repairs, and a single 68.0% would prescribe neither.

On the same slice of 243 escalated queries, Dual-RAG attains Recall@3 = 0.930 (95% CI 0.891–0.956) and MRR 0.803, which sits comfortably above the attribution figures and closes the argument: retrieval is not what limits the 80.0%. The unfavourable half is equally clear. Over the whole ground_truth set of 1,305 queries, Recall@3 collapses to 0.385, because flow-only samples dominate that population and carry no application-layer text to match—T1110 scores hit@3 of 0.00 across 236 queries. The two numbers describe different populations, and setting 0.385 against the 80.0% would breach the principle of Section 4.1.

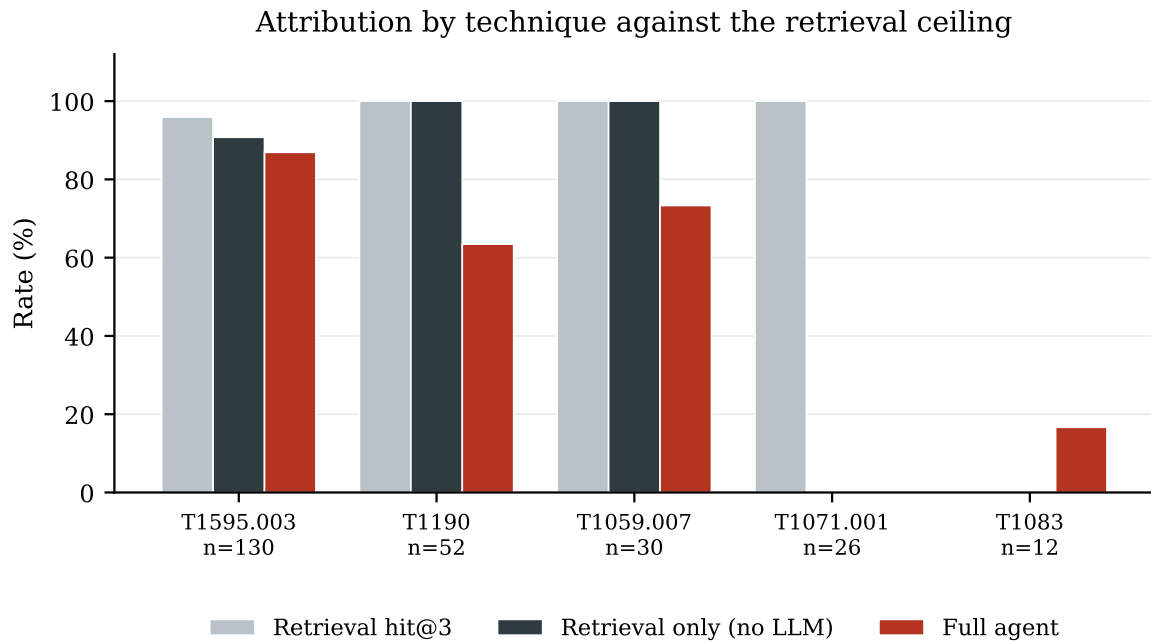


Figure 9. Attribution by technique against the retrieval ceiling. Where the light bar is high and the dark bars are zero, the mapper is at fault; where the light bar is zero, the knowledge base is. Generated from the three RQ3 result files. (Source: Author)

Reading only final verdicts would score *any* shield at zero hallucinations, including one that does nothing, so the measurement runs on traces recording the action before and after the shield: of 1,566 batches, 1,421 asserted a technique, and zero of those 1,421 were unanchored—zero even when relaxed to the parent technique. The shield is not inert while achieving this: it fired on 9.26% of batches and in 76 of them downgraded BLOCK_IP to AWAIT_HITL, preventing 76 automatic permanent IP blocks whose justification could not be anchored. One limit is stated proactively: the score uses the strict criterion that the identifier appear among retrieved document IDs, whereas the deployed shield matches by regular expression across the full context, so zero is an upper bound on leakage rather than an exact count.

Tier 1 escalated 1,066 alerts of which only 80 (7.5%) were genuine threats. As a binary classifier over that queue the model is worthless: it flagged all 1,066, dismissed none of the 986 false alarms, and scores MCC 0.0 and Balanced Accuracy 0.5, with a 99.55% false-positive rate inside the subset it actively confirmed. Its confidence is actively misleading rather than merely uninformative—mean confidence 0.846 against a true rate of 7.5%, an expected calibration error of 0.803, and the 900 highest-confidence adjudications correct

zero times.

The value sits in the channel the binary framing ignores. The agent deferred 168 alerts, 15.76% of the input, and that queue holds 76 of the 80 genuine threats (95.0%) at a true-alert density of 45.24% against 7.5% at the input: a $6.03\times$ enrichment, so an analyst reviewing only the deferred queue reads 84.24% less material while still seeing 95.0% of the real threats. The conclusion is a finding, not a defence: this model is usable as a triage router and not as an autonomous confirmer. MCC 0.0 does not contradict RQ3, which asks for reduction and *accurate triage* of the work requiring a human; and since 910 of the 1,066 escalations were benign CSIC traffic, the figure also reflects Tier 1’s escalation decision, not the agent’s alone.

Tier 2 alert triage: the value is in the deferral channel, not the verdict

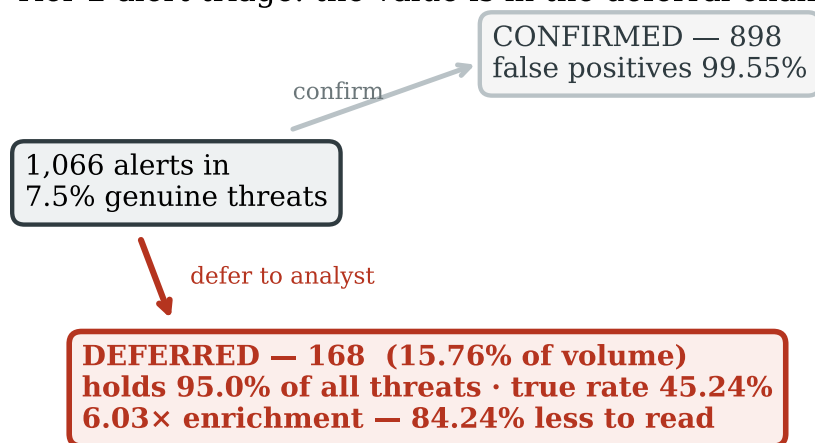


Figure 10. Alert triage at Tier 2. The confirmation channel is almost pure false positives; the deferral channel concentrates the threats. Generated from tier2_decision_results.json. (Source: Author)

A cross-family judge (Meta-Llama-3-8B-Instruct scoring Foundation-Sec-8B-Instruct) graded all 1,052 escalated events on the four RAGAS axes [37], following the recommended protocol against Self-Enhancement Bias [38]: context precision 2.54, answer relevancy 4.52, faithfulness 3.96, context recall 4.11, mean 3.78/5.0. Two results run against the system. Context precision at 2.54 is the weakest axis and corroborates the retrieval diagnosis, since the retrieved set frequently carries entries irrelevant to the event. More seriously, evidence grounding reaches only 11.2% (95% CI 9.5–13.3): roughly nine justifications in ten quote no log value that can be checked back against the record. This is the

sharpest gap between what the architecture *guarantees* and what it *volunteers*—anchoring can prove an asserted identifier is supported, but nothing compels the surrounding prose to cite the field values that led there—so transparent forensic reporting is only partially achieved, and closing it is a matter of constraining the justification format rather than improving the model.

In the component ablation, the binary framing is unusable: at an 86.9% attack base rate every configuration scores close to that figure and the comparison collapses, which is why all configurations previously appeared identical. Scoring the final action instead—whether the emitted verdict matches the expected one across BLOCK_IP, ALERT, LOG and AWAIT_HITL—restores the discrimination. The change of metric is disclosed rather than passed over, because a metric selected after seeing results is worth distrusting; the justification is that the binary version is degenerate on this distribution, not that it was unflattering.

Table 7. Ablation scored on the final action, with the 50 author-composed samples excluded. Configurations A and F are scored on all 1,700 remaining samples; B–E on a separate 300-sample slice and therefore not directly comparable with A and F. Generated from `ablation_action_scores.json`.

Configuration	<i>n</i>	Action acc. (95% CI)	Autonomy	Deferral	Auton. prec.
A — Tier 1 only, no LLM	1,700	28.29% (26.20–30.48)	41.00%	0.00%	69.01%
F — Full two-tier system	1,700	35.35% (33.12–37.66)	55.24%	44.76%	57.72%
B — LLM, no retrieval	300	34.00% (28.87–39.53)	69.67%	30.33%	45.93%
C — + dense retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
D — + sparse retrieval	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%
E — + rank fusion	300	41.33% (35.90–46.98)	98.67%	1.33%	41.89%

Three findings follow, and the second matters most. The reasoning tier earns its cost, 35.35% against 28.29%, with non-overlapping confidence intervals. But the trade-off inverts: Tier 1 alone is the *more* reliable adjudicator whenever it commits, 69.01% autonomous precision against 57.72%, yet it commits on only 41.00% of events and leaves 59.00% unresolved, escalating them to a tier that in configuration A does not exist. The full system leaves nothing unresolved, converting that backlog into 44.76% explicit deferrals. The tiers differ less in how well they think than in what they do when they do not know—the same property the deferral channel measured from the other direction. Third, a null

result: C, D and E are identical to the digit, so adding sparse retrieval to dense and fusing the rankings changes no adjudication here. That is a limitation of the ablation design rather than evidence the retrieval ladder is inert, since all three invoke the model only on escalated events and the rest of the slice falls through to the same `tier1_verdict`. Isolating rank fusion needs an evaluation restricted to escalated events, which the retrieval measurement above provides and this ablation does not.

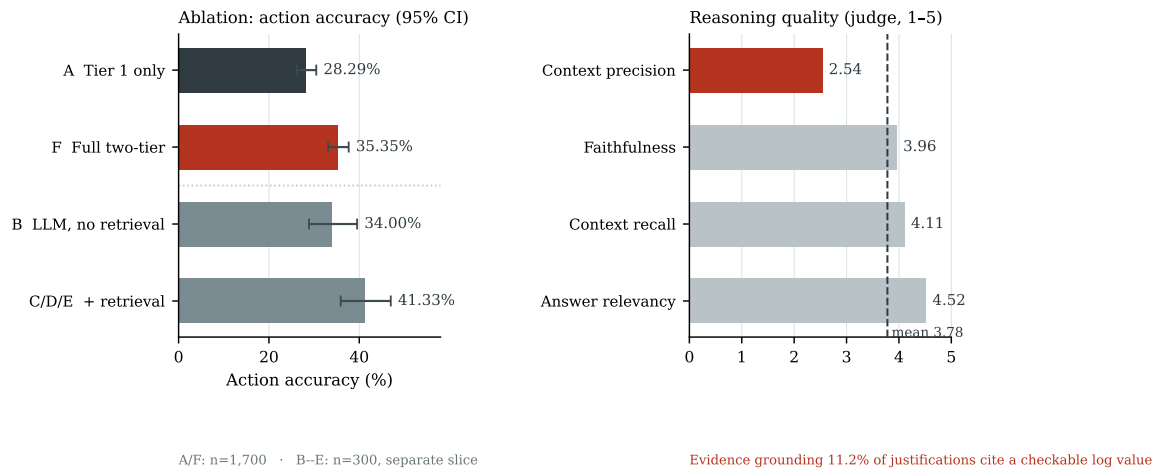


Figure 11. Left: action accuracy by configuration with 95% confidence intervals; A and F share a denominator, B–E do not. Right: the four judge axes, with context precision the weak one. Generated from `ablation_action_scores.json` and `reasoning_eval_results.json`. (Source: Author)

Stateful correlation reconstructed all 3 of 3 genuine multi-day DAPT2020 chains with no false campaign alert on the 4 benign sequences, but three positives put the 95% confidence interval on recall between 0.44 and 1.00, compatible both with a system that works and with one that was lucky, so multi-stage correlation remains proof-of-concept. Finally, a seemingly negative result confirms the design: on the non-NetFlow group the ML Gate attains only 11.1% Recall and 305 of the full set’s 336 misses fall inside it, because the Gate is trained on flow features while web attacks live in the payload—the work assigned to Tier 2 and the signature set. The aggregate Recall of 0.755 therefore mixes two non-additive populations and must be reported separately. Relatedly, and as stated in Section 3.4, the escalation-to-analyst rate is not a quantity to be minimised: an architecture claiming a zero human-review rate under all conditions has discarded its final guardrail.

Chapter 5

Conclusion

A Security Operations Centre rarely fails because an intrusion went undetected. It fails at the step after detection, where a finite number of specialists must decide which of an effectively unbounded stream of alerts deserves their attention. Language models are the first technology capable of reading an event in its context and explaining it in words a person can act on, yet placing one in an operational stream imposes costs in time, trust and data sovereignty that no headline accuracy figure addresses. This thesis asked whether that capability can be obtained without paying its full price, and answered by building SENTINEL—a two-tier architecture that settles cheap decisions before expensive ones, deployed entirely on a local workstation—and then measuring it rather than describing it. Three results carry the claim.

The economics of tiering hold, and hold as a law rather than a single number. Tier 1 and the Machine Learning Gate resolve 90.6% of a benchmark stream carrying more than three times the realistic attack proportion, and 97.5% of a stream at a near-realistic base rate, in both cases without a single language model invocation. Because the typical event never reaches the model, median end-to-end latency falls to 0.88 ms from 17,174.7 ms under a single-tier baseline. The methodological result matters more than either figure: offload decomposes linearly into a benign-case and an attack-case rate, making it a function of the stream's attack base rate rather than a constant of the system—a property that lets the measurement transfer to another environment, and that a single quoted percentage cannot support.

The security guarantee is structural, and therefore does not decay. Delimited Data Encapsulation treats content inside a per-batch nonce boundary as passive text regardless of what

it says, and resisted all 678 adversarial samples in the categories the inexpensive static pre-filter cannot absorb—precisely the categories that filter is blind to. This is a different kind of assurance from a classifier that blocks $x\%$ and leaks the remainder against every novel phrasing. HMAC-SHA256 chaining detects 100% of the three core tampering modes with no false alarm over an intact control chain, sealing the forensic record with integrity and tamper-evidence.

Hallucination control became a verifiable constraint rather than a hope. Every ATT&CK identifier the system emits must appear in that batch’s retrieved documents; across 1,421 adjudications asserting a technique, zero were unanchored. That zero is not the trivial score of a shield that never acts: it intervened on 9.26% of batches, and 76 of those interventions withheld a permanent IP block the system could not justify from evidence. The reasoning tier also proved most valuable in a role other than the obvious one—used as a triage router rather than an autonomous confirmer, its deferral queue concentrates 95.0% of genuine threats into 15.76% of the volume, a $6.03\times$ enrichment that removes 84.24% of the material an analyst must read.

The architecture’s limits are reported in full where their evidence lives, in Chapter 4, and three set the immediate agenda: attribution is currently better without the reasoning tier than with it, the agent cannot yet dismiss a false alarm on its own, and the explanation layer is the weakest link, since retrieval admits irrelevant material and only 11.2% of justifications cite a log value that can be checked back against the record. The corresponding directions are a retrieval layer repaired at the knowledge-base level, calibration for dismissal as well as confirmation, and a justification format that compels citation rather than merely permitting it. Two smaller extensions follow from properties already stated: anchoring hash values periodically outside the system would close the tail-truncation blind spot inherent to log chaining, and asymmetric signatures would upgrade tamper-evidence to genuine non-repudiation.

Concluding a rigorous research endeavor, while opening inspiring horizons in securing the digital realm through the power of Agentic Artificial Intelligence.

References

- [1] G. González-Granadillo, S. González-Zarzosa, and R. Diaz, “Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures,” *Sensors*, vol. 21, no. 14, art. 4759, 2021.
- [2] S. Tariq, M. Baruwat Chhetri, S. Nepal, and C. Paris, “Alert Fatigue in Security Operations Centres: Research Challenges and Opportunities,” *ACM Computing Surveys*, vol. 57, no. 9, art. 224, 2025.
- [3] B. A. AlAhmadi, L. Axon, and I. Martinovic, “99% False Positives: A Qualitative Study of SOC Analysts’ Perspectives on Security Alarms,” in *Proceedings of the 31st USENIX Security Symposium*, 2022, pp. 2783–2800.
- [4] Ismail, R. Kurnia, Z. A. Brata, G. A. Nelistiani, S. Heo, H. Kim, and H. Kim, “Toward Robust Security Orchestration and Automated Response in Security Operations Centers with a Hyper-Automation Approach Using Agentic Artificial Intelligence,” *Information*, vol. 16, no. 5, art. 365, 2025.
- [5] A. Vaswani *et al.*, “Attention is All You Need,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 30, pp. 5998–6008, 2017.
- [6] K. Greshake, S. Abdelnabi, S. Mishra, A. Endres, T. Holz, and M. Fritz, “More than you’ve asked for: A Comprehensive Analysis of Novel Prompt Injection Threats to Application-Integrated Large Language Models,” *arXiv preprint arXiv:2302.12173*, 2023.
- [7] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST Special Publication 800-207, National Institute of Standards and Technology, 2020.
- [8] OWASP GenAI Security Project, “OWASP Top 10 for Large Language Model Applications,” Version 2025, The OWASP Foundation, 2025. [Online]. Available: <https://genai.owasp.org/>
- [9] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, “Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization,” in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.
- [10] C. Torrano-Giménez, A. Pérez-Villegas, and G. Álvarez Marañón, “HTTP DATASET CSIC 2010,” Information Security Institute, Spanish National Research Council (CSIC), 2010. [Online]. Available: <https://www.isi.csic.es/dataset/HTTP>
- [11] S. Myneni, A. Chowdhary, A. Sabur, S. Sengupta, G. Agrawal, D. Huang, and M. Kang, “DAPT 2020 – Constructing a Benchmark Dataset for Advanced Persistent Threats,” in *Deployable Machine Learning for Security Defense (MLHat 2020)*, Communications in Computer and Information Science, vol. 1271, Springer, 2020, pp. 138–163.
- [12] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and Transferable Adversarial Attacks on Aligned Language Models,” *arXiv preprint arXiv:2307.15043*, 2023.
- [13] Deepset, “Prompt Injections Dataset,” *Hugging Face repository*, 2023. [Online]. Available: <https://huggingface.co/datasets/deepset/prompt-injections>
- [14] jackhhao, “Jailbreak Classification Dataset,” *Hugging Face repository*, 2023. [On-

- line]. Available: <https://huggingface.co/datasets/jackhhao/jailbreak-classification>
- [15] R. Zuech, T. M. Khoshgoftaar, and R. Wald, "Intrusion Detection and Big Heterogeneous Data: A Survey," *Journal of Big Data*, vol. 2, art. 3, 2015.
 - [16] B. P. Welford, "Note on a Method for Calculating Corrected Sums of Squares and Products," *Technometrics*, vol. 4, no. 3, pp. 419–420, 1962.
 - [17] A. Gholami *et al.*, "A Survey of Quantization Methods for Efficient Neural Network Inference," *arXiv preprint arXiv:2103.13630*, 2021.
 - [18] S. Weerawardhena, P. Kassianik, B. Nelson, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-8B-Instruct Technical Report," *arXiv preprint arXiv:2508.01059*, 2025.
 - [19] P. Kassianik, B. Saglam *et al.* (Cisco Foundation AI), "Llama-3.1-FoundationAI-SecurityLLM-Base-8B Technical Report," *arXiv preprint arXiv:2504.21039*, 2025.
 - [20] LangChain AI, "LangGraph: Multi-Actor, Stateful LLM Applications," *GitHub repository*, 2024. [Online]. Available: <https://github.com/langchain-ai/langgraph>
 - [21] P. Lewis *et al.*, "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks," *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 33, pp. 9459–9474, 2020.
 - [22] J. Johnson, M. Douze, and H. Jégou, "Billion-Scale Similarity Search with GPUs," *IEEE Transactions on Big Data*, vol. 7, no. 3, pp. 535–547, 2021.
 - [23] S. Robertson and H. Zaragoza, "The Probabilistic Relevance Framework: BM25 and Beyond," *Foundations and Trends in Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009.
 - [24] G. V. Cormack, C. L. A. Clarke, and S. Buettcher, "Reciprocal Rank Fusion Outperforms Condorcet and Individual Rank Learning Methods," in *Proceedings of the 32nd International ACM SIGIR Conference on Research and Development in Information Retrieval*, 2009, pp. 758–759.
 - [25] R. Pandey and A. Bhujang, "Poisoning the Watchtower: Prompt Injection Attacks Against LLM-Augmented Security Operations Through Adversarial Log Content," *arXiv preprint arXiv:2605.24421*, 2026.
 - [26] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-Hashing for Message Authentication," Internet Engineering Task Force, RFC 2104, 1997.
 - [27] J. Zhang *et al.*, "When LLMs Meet Cybersecurity: A Systematic Literature Review," *Cybersecurity*, vol. 8, 2025.
 - [28] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An Agentic RAG cyber attack classification and reporting tool," *Future Generation Computer Systems*, vol. 176, art. 108186, 2026.
 - [29] Z. Liu and A. Anwar, "AutoBnB-RAG: Enhancing Multi-Agent Incident Response with Retrieval-Augmented Generation," *arXiv preprint arXiv:2508.13118*, 2025.
 - [30] A. Abdennebi, N. Kara, L. Lahlou, and H. Ould-Slimane, "LanG – A Governance-Aware Agentic AI Platform for Unified Security Operations," *arXiv preprint arXiv:2604.05440*, 2026.
 - [31] R. Sahay *et al.*, "Policy-Guided Threat Hunting: An LLM Enabled Framework with Splunk SOC Triage," *arXiv preprint arXiv:2603.23966*, 2026.
 - [32] P. He, J. Zhu, S. He, J. Li, and M. R. Lyu, "Drain: An Online Log Parsing Approach with Fixed Depth Tree," in *Proceedings of the IEEE International Conference on Web Services (ICWS)*, 2017, pp. 33–40.
 - [33] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, and C. B. Thomas, "MITRE ATT&CK: Design and Philosophy," The MITRE Corporation,

Technical Report MP180360, 2018.

- [34] P. Cichonski, T. Millar, T. Grance, and K. Scarfone, “Computer Security Incident Handling Guide,” NIST Special Publication 800-61 Revision 2, 2012.
- [35] N. Reimers and I. Gurevych, “Sentence-BERT: Sentence Embeddings using Siamese BERT-Networks,” in *Proceedings of the Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2019.
- [36] X. Shen, Z. Chen, M. Backes, Y. Shen, and Y. Zhang, “‘Do Anything Now’: Characterizing and Evaluating In-The-Wild Jailbreak Prompts on Large Language Models,” in *Proceedings of the 2024 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2024, pp. 1671–1685.
- [37] S. Es, J. James, L. Espinosa-Anke, and S. Schockaert, “RAGAS: Automated Evaluation of Retrieval Augmented Generation,” *arXiv preprint arXiv:2309.15217*, 2023.
- [38] L. Zheng *et al.*, “Judging LLM-as-a-Judge with MT-Bench and Chatbot Arena,” in *Advances in Neural Information Processing Systems (NeurIPS)*, vol. 36, 2023.